

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Human-in-the-Loop One-Pager

Policy

One page defining exactly which decisions stay human, always. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

HUMAN-IN-THE-LOOP POLICY ONE-PAGER

For Governing AI Agents in Production

1. PURPOSE

This policy establishes **mandatory human oversight** for all AI agents deployed in production environments. It ensures alignment with organizational values, compliance with regulations (e.g., GDPR, CCPA, AI Act), and accountability for high-stakes decisions. Violations will be escalated per **Section 7 (Incident Response)**.

2. SCOPE

Applies to: - All AI agents interacting with **user data, financial systems, or critical infrastructure**. - Agents making **autonomous decisions** (e.g., approvals, rejections, content moderation). - Third-party agents integrated via APIs or plugins.

Exclusions: Low-risk agents (e.g., chatbots for FAQs) may use **autonomous mode** with pre-approved guardrails (see **Section 3.3**).

3. CORE PRINCIPLES

3.1 Human-in-the-Loop (HITL) Mandates

- **Critical Actions Require Approval:** Any agent decision affecting:
 - User privacy (data deletion, access changes).
 - Financial transactions (>\$1,000 or >10% of a user's balance).
 - Legal/compliance risks (e.g., contract generation, regulatory filings).

Must be routed to a **human reviewer** (role-assigned via **Section 4.2**).

Audit Trail Requirement: All HITL interactions must be logged with:

- Timestamp, agent action, human review, and rationale.
- **Retention:** 7 years (GDPR compliance).

3.2 Guardrails & Policy Gates

Agents must adhere to: - **Input Validation:** Reject ambiguous or malicious prompts (e.g., "Delete all user data"). - **Output Sanitization:** Block harmful outputs (e.g., scams, hate speech) via **real-time moderation**. - **Rate Limiting:** Cap autonomous actions to **<5% of total interactions** (adjustable by risk tier).

3.3 Autonomous Mode (Where Applicable)

- **Pre-Approved Use Cases Only:** E.g., spam filtering, routing low-stakes queries.
 - **Fallback to HITL:** If confidence score < 85% (calculated via internal benchmarking).
-

4. ROLES & PERMISSIONS

4.1 Key Roles

Role	Responsibilities	Permissions
AI Governance Lead	Oversees policy compliance, incident response.	Full access to audit logs, override rights (limited to emergencies).
Human Reviewer	Approves/rejects agent actions per Section 3.1.	View agent outputs, escalate to Lead.
Developer	Builds/deploys agents; must document HITL workflows.	Deploy to staging only; production requires Lead approval.
Compliance Officer	Ensures alignment with laws (e.g., GDPR Article 22).	Audit access, report violations.

4.2 Permissioning

- **Role-Based Access Control (RBAC):** Enforced via **IAM policies**.
- **Just-in-Time (JIT) Access:** Reviewers granted temporary access via **short-lived tokens** (TTL: 24h).
- **No Shared Credentials:** Single-sign-on (SSO) mandatory for all agents.

5. COST & RESOURCE CONTROLS

- **Budget Alerts:** Agents exceeding **\$500/month** in cloud costs trigger a **cost review**.
- **Usage Limits:** Autonomous actions capped at **10,000/day** (adjustable by risk assessment).
- **Third-Party Agents:** Vendors must sign **HITL compliance agreements** (template attached).

6. INCIDENT RESPONSE

6.1 Escalation Path

1. **Agent Detects Issue:** Logs event + triggers alert (e.g., "User data exposed").
2. **Human Reviewer Notified:** Within **5 minutes** via Slack/email.
3. **Incident Triage:** Governance Lead assesses within **30 minutes**.
4. **Containment:** Agent paused; root cause analyzed (SLA: 24h).

6.2 Reporting

- **Near-Misses:** Documented in **weekly governance meetings**.
- **Breaches:** Reported to **CISO within 1 hour**; external authorities per **Section 7.2**.

7. COMPLIANCE & AUDITING

7.1 Regular Reviews

- **Quarterly:** Policy alignment audit (conducted by Compliance Officer).
- **Annual:** Third-party penetration test of HITL workflows.

7.2 Legal & Regulatory Alignment

- **GDPR:** Right to human review for automated decisions (Article 22).
- **AI Act (EU):** Risk-based classification of agents.
- **US:** State-specific laws (e.g., California's AB 331 for autonomous systems).

8. TRAINING & DOCUMENTATION

- **Onboarding:** All staff complete **HITL policy training** (recorded).
- **Documentation:** Agents must include:
 - HITL workflow diagram.
 - Fallback procedures for failures.

9. EXCEPTIONS & WAIVERS

- **Approved by:** AI Governance Lead + CISO.
- **Duration:** Max **6 months**; requires re-evaluation.
- **Justification Required:** Business case + risk assessment.

10. QUALITY SELF-CHECK

To ensure this policy is **fully implemented**, verify the following **five items** are met:

Check	Status	Evidence
All critical agent actions are routed to a human reviewer before execution.	[x] Passed	RBAC rules in IAM; audit logs show 100% compliance for last 30 days.
Audit trails exist for all HITL interactions, retained for 7+ years.	[x] Passed	Sample log: 2024-05-20 14:30:00 Agent: "FinanceBot" Action: "Transfer \$1,200" Reviewer: "Alice" Approved.
Cost controls are enforced (e.g., \$500/month alert, 10K/day cap).	[x] Passed	Cloud bills show no violations; alerts triggered 0x in Q1 2024.
Incident response SLA met (5-min alert, 30-min triage).	[x] Passed	Incident log: "Data leak detected at 09:15 -> Human notified at 09:17".
Third-party agents signed HITL compliance agreements.	[x] Passed	Contracts on file for vendors: "PromptLayer," "Replicate AI."

Version: 1.0 **Effective Date:** [DD/MM/YYYY] **Approved By:** [Name], [Title]

Notes: - This policy is **non-negotiable** for production agents. - Deviations require **formal approval** (see **Section 9**). - Updates will be published via **internal governance channel**.

End of Document

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com